

The OWASPTM OT Top 10

Security Forum 2026

Felix Eberstaller & Nino Fürthauer



Who we are

- Passion for OT/IoT security
- Vendor-neutral approach
- Owner-operated business
- European
- 25+ highly qualified OT security experts
- Focus on real and sustaining security improvements



What we help with

We help you to identify defects in your products and solutions, assist with the setup of secure development practices and coach you to deal with vulnerabilities in the long run.



We assist you with identifying technical and organizational weaknesses in your organization, aid you in setting up effective and efficient security organizations and implement appropriate countermeasures.



We enable you to build and integrate security capabilities into your organization through top-class security trainings and certification of your staff.



We provide you with structured assessments of the security posture of industrial control and automation systems, identifying relevant risks and vulnerabilities. Based on the findings, concrete measures are defined to improve cyber resilience.



SIEMENS

Mercedes-Benz Group AG

EVN

A|S|F|i|N|A|G

illwerke  **vwk**

WESTERMO

ekey
YOUR FINGER. YOUR KEY.

WienCERT
IKT-Sicherheit im Maßstab

StoDt+WiEn
Wien ist anders.

WIENER  **NETZE**

FESTO

Austrian 

RONAL GROUP

 **LineMetrics**

LGSolutions

ENERGIEAG
Oberösterreich

 **IFE**

 **TINETZ**

SIEMENS Gamesa
RENEWABLE ENERGY

GINZINGER
electronic systems

KAGes


SAFECode
Software Assurance Forum for Excellence in Code
Driving Security and Integrity

Rosenberger

 **TAG**

 **FRAUSCHER**

Landes
Zahnärztekammer
Wien

 **commend**

 **COPADATA**

 **CELUM**



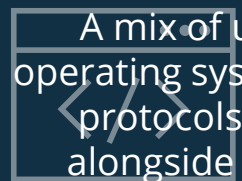
OWASP OT Top 10

Where do we find Operational Technology?

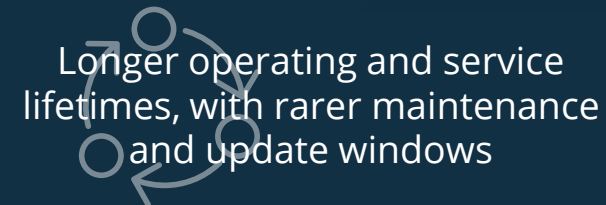


What is OT-Security?

OT has different characteristics from conventional IT systems, including different risks and priorities ... which is why OT security is not the same as IT security



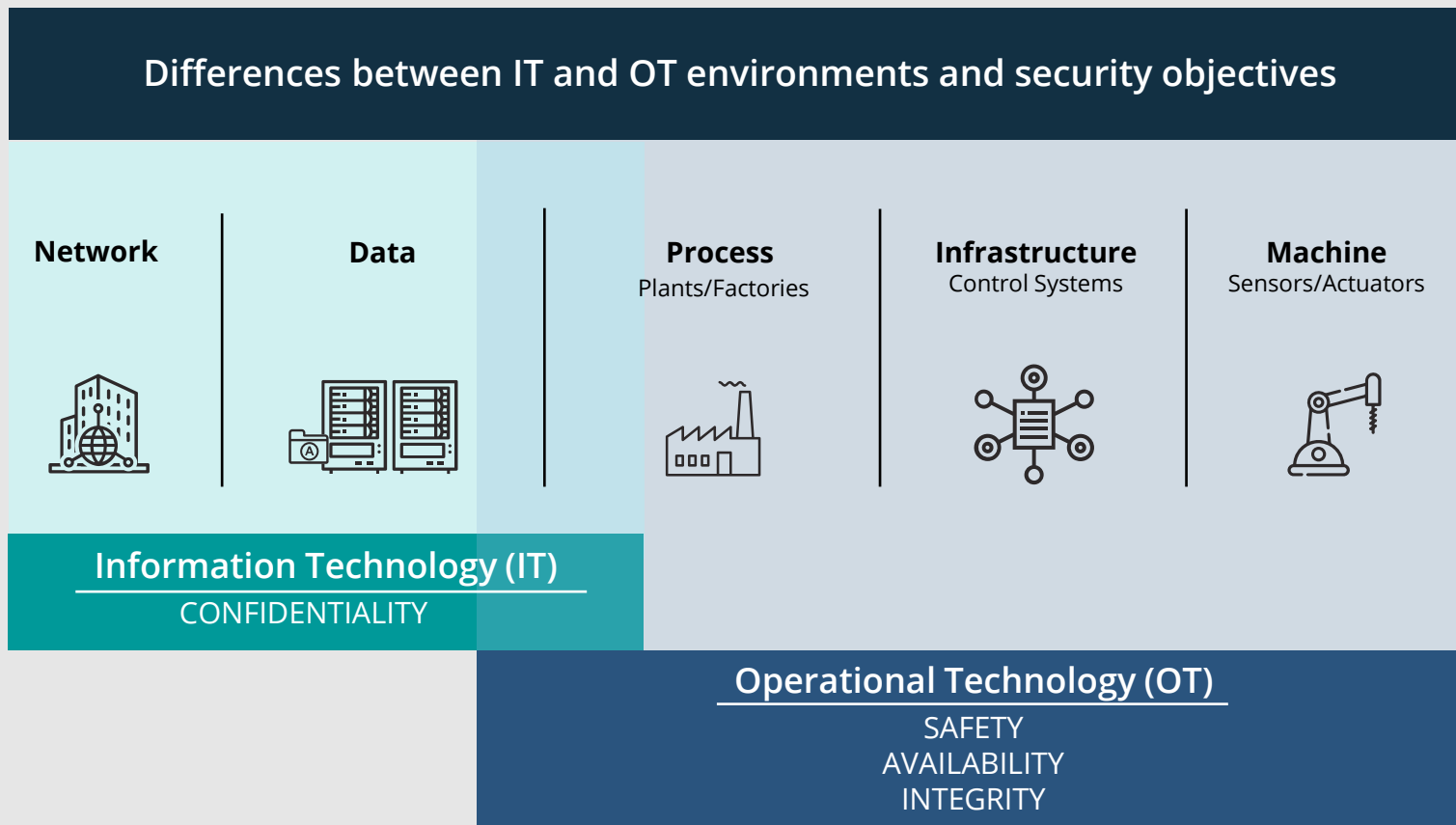
A mix of unconventional operating systems, applications, protocols, and hardware alongside COTS¹ products



¹ Commercial off-the-shelf

Challenges in OT

In OT environments, security objectives are weighted differently than in IT environments, leading to different requirements for the systems.



Security objectives in the OT environment (SAIC)

SAFETY

AVAILABILITY

INTEGRITY

CONFIDENTIALITY

Avoiding production outages is
(usually) the top priority!





OT Security and the Lifecycle of an Industrial Plant

Procurement, commissioning, operation, maintenance / expansion / modification, decommissioning: every phase must be protected accordingly.

Long maintenance and update cycles

- Some plants are built to run for 20–30+ years
- Rare update windows (often tied to scheduled shutdowns)
- Many legacy systems with long-obsolete OS and firmware versions

Changes are complex and rarely DIY

- Modifications often require integrators, vendors, or OEMs
- Support contracts/warranties may prohibit unauthorized changes (incl. security patches!)
- Change windows must be coordinated across operations, safety, quality, and the supply chain

The importance of OT Security

To prevent serious harm to people and infrastructure, security must become a built-in part of how OT is designed, built, and operated, not an afterthought.

Connectivity is exploding

- Plants and field devices are increasingly internet-connected, accelerated by (I)IoT and remote-service models
- Every new connection is a new potential attack path
- Classic "air-gapped OT" assumption often no longer holds

Regulation is catching up fast

- OT security is moving from optional to mandatory under regulations, standards, and laws
- Key frameworks: NIS2 Directive, BSI-KRITIS Ordinance, EU Cyber Resilience Act (CRA) for manufacturers, IEC 62443 as the de-facto OT security standard
- Non-compliance increasingly carries personal liability for management and significant fines

The importance of OT Security

To prevent serious harm to people and infrastructure, security must become a built-in part of how OT is designed, built, and operated, not an afterthought.

The threat landscape has changed

- Attackers have an increasing interest in OT
- Attackers try to understand the process landscape
- Ransomware in OT is on the rise
- Geopolitical tensions drive attacks

The skills and culture gap

- IT and OT teams often speak different languages and have different priorities
- OT teams optimised for safety, uptime, and process quality, not for cybersecurity
- IT teams often have little understanding of OT constraints





OT Top 10





Open Worldwide Application
Security Project

- **Global open community** focused on improving security through education, tools, and collaboration.
- Projects try to provide **practical guidance and resources**
- Best known for the **OWASP Top 10** for web application security risks
- Projects apart from Top 10 (examples):
 - Various cheat sheets
 - Various standards like ASVS (Application Security Verification Standard)
 - *AI Exchange*
 - *ZAP* (Security scanner for web apps)
 - *Juice Shop* (intentionally insecure web application)



OWASP OT Top 10

Goal

- Highlight the most relevant OT-specific security issues
- Provide actionable recommendations
- Improve the security posture of OT systems
- Foster understanding between IT and OT staff



OWASP OT Top 10

Methodology



Limes experts contributed to the development of the OWASP OT Top 10!

- Joint effort by OWASP, industry, and federal authorities (e.g., BMI)
- Expert discussions
- Analysis of advisories and reports
- Empirical data from offensive and defensive OT security projects



OWASP OT Top 10

Scope

In scope:

- Core OT systems and devices
 - e.g. CNC machines, SCADA systems, centrifuges, insulin pumps, HVAC
- Related supporting devices
 - e.g. HMIs, barcode scanners, shop-floor surveillance cameras, virtualization servers and VMs with core functionality

Out of scope

- Office IT
- Edge devices not directly related to the main OT purpose



OWASP OT Top 10

Target Audience

- Vendors
- Integrators
- Operator

...and everyone in between
should get something out of it!



While developers can proactively create secure components, integrators and operators are often limited to implementing mitigations.



OT Kill Chain



OT Kill Chain – Stage 1

STAGE I Cyber Intrusion Preparation and Execution



Stage I mimics a targeted and structured attack campaign.

Source: <https://sansorg.egnyte.com/dl/HHa9fCekmc>

Planning and Preparation

Similar to classical IT Cyber Kill Chain from Lockheed Martin

Planning

- Reconnaissance - gather intelligence on the target
 - Passive / OSINT (Google, Shodan, social media, vendor docs)
 - Active (scanning, probing exposed services)

Preparation

- Weaponization -generate malicious payload
 - PDFs, macros, scripts, binaries
- Targeting — choose attack vector
 - VPN, internet-facing firewall, web server, e-mail



Cyber Intrusion

Similar to classical IT Cyber Kill Chain from Lockheed Martin

Delivery

- Interaction with the internal network, e.g.
 - Phishing mail delivers malicious PDF file
 - VPN connection forwards attacker directly to internal network
 - Other vectors: watering-hole websites, USB drops, trojanized installers...

Exploit

- Adversary performs malicious action , e.g.
 - Malicious PDF file was opened
 - Use obtained credentials for VPN connection
 - Note: Exploitation isn't always a CVE, abusing legitimate access counts too!

Install/Modify

- Establish foothold
 - Install capability: Remote Access Trojan (RAT)...
 - Use what's already there (Living off the Land): PowerShell, cmd, bash, Python, Ruby, gcc, WMI, scheduled tasks ...



Management and Enablement

Similar to classical IT Cyber Kill Chain from Lockheed Martin

C2 (Command and Control)

- Initiate persistent access
 - Connection won't get lost despite of detection/deletion, restarts...
 - Often hidden in incoming or outgoing communication, existing connections get hijacked
 - In case of physical access: specialised equipment can be used (e.g., LAN Turtle)

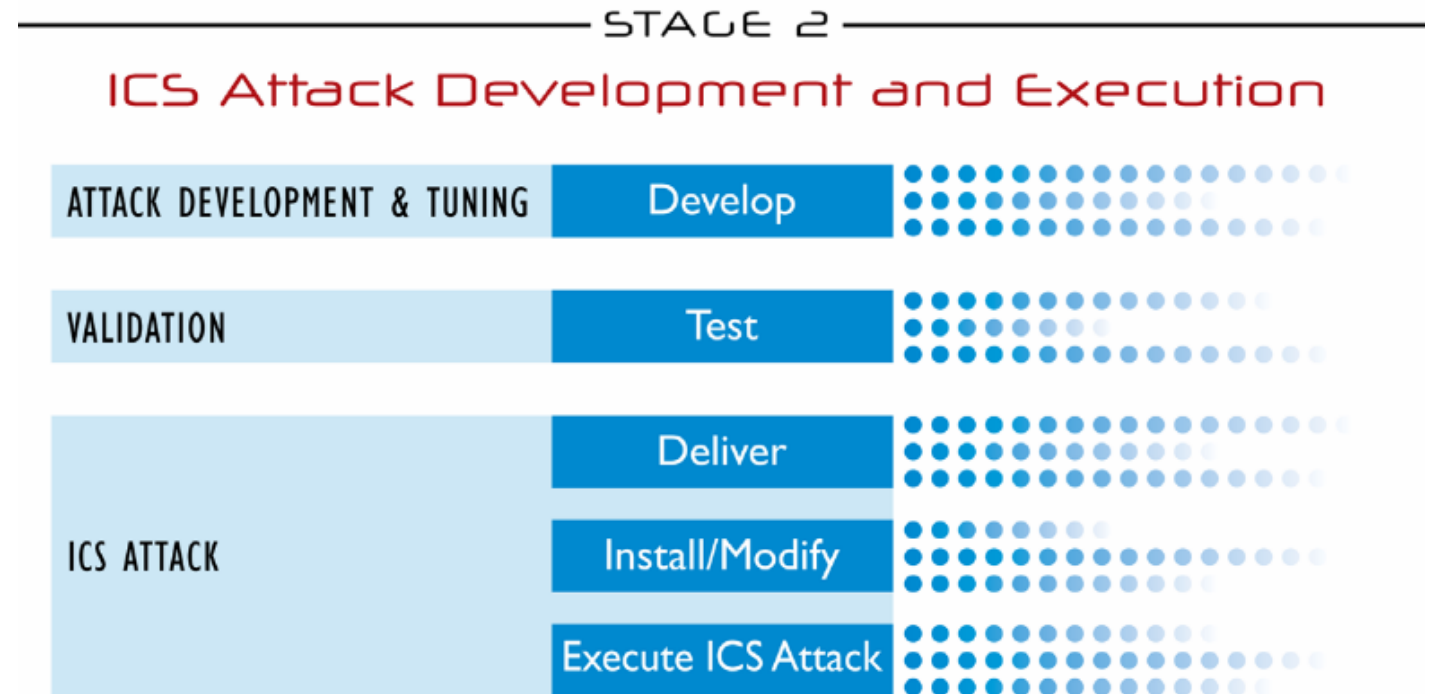
Sustainment, Entrenchment, Development & Execution

Similar to classical IT Cyber Kill
Chain from Lockheed Martin

Act

- Accomplish the goals of the attack
 - Data theft / espionage
 - Encrypt data (ransomware)
 - Move to other networks
 - Sabotage

OT Kill Chain – Stage 2



Source: <https://sansorg.egnyte.com/dl/HHa9fCekmc>



Attack Development & Tuning

(Process-)specific, individual attack is developed

- Usually **offline in attacker's lab** based on exfiltrated data
- Can require **significant process and OT know how**
- Can be **hard to detect** since there is no activity on the victim network during this phase
- Typically **significant delay** between stage 1 and finishing this phase (months to years)

Validation

Test capability before committing to the live target

- Run against **similar or identically configured systems** with the same PLC firmware, HMI version, and process logic
- **Digital twins**, lab replicas, or acquired physical ICS equipment
- Even simple effects (e.g., scan-induced denial of service) need confirmation that they reliably produce the intended impact

Attack

Validated capability is delivered to the live target and effect is produced

- **Deliver** the payload into the OT environment (engineering workstation, USB, infected update, lateral movement from IT...)
- **Install / Modify** by implanting code or altering existing system functionality (PLC logic, firmware, HMI projects...)
- **Execute** the attack, often combined with enabling actions (disable alarms, suppress logging) and supporting actions (spoof HMI values so operators see "normal")

Impact categories

- **Loss** of View / Control / Safety: Asset is gone, often unintentionally
- **Denial** of View / Control: Asset is actively blocked (frozen HMI, dropped commands)
- **Manipulation** of View / Control / Sensors and Instruments: Asset still works but lies (false readings, altered setpoints, falsified field data)

Attack Campaign FrostyGoop / BUSTLEBERM

Stage 1

Planning: Reconnaissance

- Lvivteploenergo identified as municipal district heating utility (~600 buildings, ~100k residents in the Sykhiv district)
- Internet-facing MikroTik router discovered as exposed entry point
- ENCO heating controllers profiled — Modbus TCP/502 reachable, port 23 (Telnet) exposed

Preparation: Weaponization & Targeting

- Exploit prepared for MikroTik router vulnerability
- ReGeorg-like webshell staged for tunnelling
- Target chosen for maximum civilian impact during winter; weak IT/OT segmentation made it attractive

Cyber Intrusion: Attempt: Delivery & Exploit

- 17 April 2023, exploit delivered to externally facing MikroTik router
- Undetermined router vulnerability successfully exploited

Attack Campaign FrostyGoop / BUSTLEBERM

Stage 1

Management & Enablement

- Long-term C2 via the webshell tunnel (April 2023 – January 2024)
- 22 January 2024, re-entry over L2TP from **Moscow-based IP addresses**

Sustainment, Entrenchment, Development & Execution

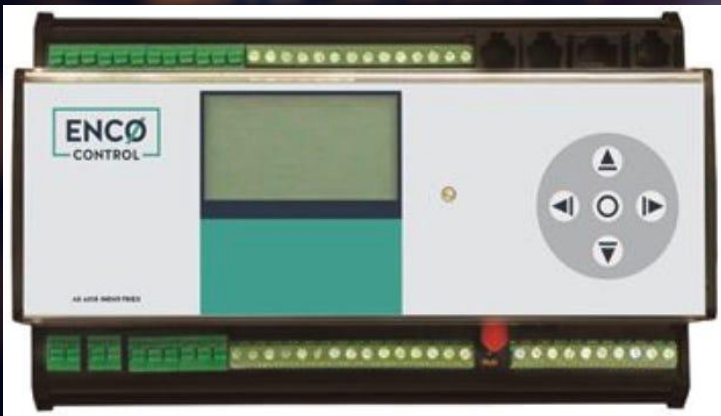
- Nov–Dec 2023, credential theft from **Windows SAM registry hive**
- Lateral movement across four management servers
- Network routes leveraged to reach the OT segment directly
- ~9-month dwell time before pivot to Stage 2



Attack Campaign

FrostyGoop / BUSTLEBERM

Stage 2



Attack Development & Tuning

- **FrostyGoop / BUSTLEBERM** built in Golang, compiled for Windows
- Uses an obscure open-source Modbus library; JSON config (task_test.json) defines target IPs and Modbus commands
- Implements function codes **FC3 (read)**, **FC6 (write single)**, **FC16 (write multiple)** over Modbus TCP/502
- Firmware-downgrade payload prepared using **a legitimately signed older ENCO firmware (v50)** that lacked the operator's monitoring features

Validation

- Likely tested against other internet-exposed ENCO controllers (Unit 42 later found 32 such devices across Ukraine and Romania)
- Dragos initially assessed the first samples as "testing-stage" before linking them to Lviv
- Undetected by mainstream antivirus throughout

Attack Campaign FrostyGoop / BUSTLEBERM

Stage 2

```
=====
Enco control Telnet Server v1.00
=====

Available Commands:
-----
ethr      - ethernet connection list
gprs      - gprs connection list
tcpconn   - tcp connections
ipstat    - IP statistics
icmpstat  - ICMP statistics
tcpstat   - TCP statistics
udpstat   - UDP statistics
owire     - one wire temperature sensors list
io        - inputs/outputs state
outX=Y    - change output X=(0 or 1) state Y=(0 or 1)
cport[=password,XXXX] - config port
rst=password - restart device
disc x1.x2.x3.x4 - disconnect ip
ntp       - ntp correction
help,?    - display this help
exit,<Ctrl+C> - disconnect
```

Deliver

- FrostyGoop binary placed on a compromised Windows management server inside the victim network
- Modbus commands sent directly from adversary hosts to ENCO controllers via hardcoded routes

Install/Modify

- ENCO controller firmware downgraded from v51/52 → v50
- Downgrade was to a legitimately signed image, no malicious firmware to detect
- Result: Loss of View operators' monitoring capabilities silently disabled

Execute ICS Attack

- Standard Modbus writes used to alter setpoints and falsify temperature measurements
- Controllers reported water as hotter than reality → heating logic stopped → cold water pumped to apartments
- SCADA picture stayed misleading; operators blind to the manipulation

Impact:

600+ apartment buildings without heat for ~2 days in sub-zero temperatures

The OWASP OT Top 10



Explore the full OWASP OT Top 10 and its guidance

ot.owasp.org

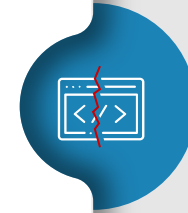


Unknown assets
and undocumented
services

01

02

Devices with known
vulnerabilities



Inadequate supply
chain management

03

04

Loss of availability



The OWASP OT Top 10



Insufficient
access control **05**



Missing incident
detection/reaction
capabilities **06**



Broken zones and
conduits design **07**



Missing
awareness **08**



Insufficient
security
capabilities **09**



Missing
hardening **10**



Structure of each Top 10 Item

Name Name/title of the item	Description Description of the item
Rationale Why did the team find this item important enough for inclusion?	
Known attacks/examples What are documented attacks that utilized the respective Top 10 item?	
Mitigation/Countermeasures 1) Design and implementation level mitigations for developers/builders; 2) Operational mitigations for integrators, e.g., air-gapping systems	
Next actionable steps What can be done to identify and/or mitigate the issue?	
References Relevant standards, links to tools and background Information	



Live Demo



From risk awareness to compliance mapping

A dedicated standards mapping has been created for each OWASP OT Top 10 item.

Explore the standards mapping table

ot.owasp.org



	IEC 62443	NIST SP 800-82 v3	NIST CSF 2.0	MITRE ATT&CK	NIS-2	ISO/IEC 27001
1. Unknown Assets and Unmanaged External Access	* FR 2 2-1 CM 1 2-1 NET 3.X 3-2 ZCR 1 3-2 ZCR 3.6 3-3 SR 2.X 3-3 SR 7.8	CM-8 AC-20 AC-17 CM-2	ID.AM PR.AA PR.IR-01	M0800 M0801 M0804 M0807 M0813 M0918 M0922 M0926 M0932	6.7 11.X 12.1 12.2 12.4	-
2. Devices with Known Vulnerabilities / Issues	* FR 3 * FR 4 3-2 ZCR 5.2 3-3 SR 3.X 3-3 SR 4.X	SI-2 RA-5 CM-6	ID.RA-01 ID.IM PR.PS DE.CM-09	M0916 M0934 M0942 M0945 M0948	6.5 6.6 6.10	-
3. Inadequate Supplier / Supply Chain Management	2-1 ORG 1.6 3-2 ZCR 5.X	SR-2 SR-3 SR-5 SR-6	GV.OC-03 GV.OC-04 GV.OC-05 GV.SC ID.RA-10	M0817	5.X 6.1 6.2	-
4. Loss of Availability	* FR 7 2-1 DATA 1.3 2-1 DATA 1.4 2-1 SPE 8 3-3 SR 7.X *=mapping refers to the IEC 62443 requirement family, not to a specific part of the standard IEC 62443	CP-2 CP-7 CP-9 CP-10	GV.OC-04 GV.OC-05 GV.SC-07 GV.SC-08 PR.AA-02 PR.IR-02 PR.IR-03 PR.IR-04 DE.CM RC.RP-01 RC.RP-02 RC.RP-04	M0803 M0811 M0812 M0815 M0953	4.X 6.4 13.1 13.2	-

- The OWASP OT Top 10 mapping table links each risk area to recognized standards and regulatory requirements.
- It references frameworks such as IEC 62443, NIST SP 800-82, NIST CSF 2.0, MITRE ATT&CK, and NIS2-related requirements.
- This helps teams translate OT security findings into control gaps, mitigation priorities, and compliance actions.



The OT Top 10 helps organizations focus on critical risks - but it does not replace a broader security strategy.





LIMES
SECURITY



office@limessecurity.com



www.limessecurity.com

Defending what matters